

TABLE OF CONTENTS

1. INTRODUCTION	2
1.1. PURPOSE	3
1.2. SCOPE	3
2. RESPONSIBILITIES	4
3. BACKGROUND	4
3.1. Summary of Procedures / SOPs	5
4. SUMMARY OF GAPS/DEVIATIONS IDENTIFIED	7
5. CORRECTIVE ACTIONS	8
6. DEPENDENCIES	10
7. CONCLUSION	10
8. DEFINITIONS & GLOSSARY	11
9. DOCUMENT REFERENCES	12
10. PUBLISHING	13
11. REVIEW	13
12. APPENDIX A	14

1. INTRODUCTION

The MyDiagnexia Group Reporting Hub is a major enhancement to the Diagnexia digital pathology platform. Its purpose is to enable decentralized, collaborative, and scalable digital pathology workflows for clinical laboratories and pathology groups globally.

Traditionally, Diagnexia services relied on a centralized slide shipment and review model, where physical glass slides were shipped to the Naperville or Toronto laboratories for scanning, QC, and reporting. While this model is compliant and effective, it introduces logistical delays, risks of slide damage, and high reliance on centralized resources.

The new My Diagnexia Group Reporting Hub fundamentally changes this model by enabling clients to:

- Digitally upload slides from their own scanners (rather than relying solely on Diagnexia-operated scanners).
- Assign and report cases within their internal pathology network (allowing hospital, lab, or regional groups to self-manage their case flow).
- Route cases to Diagnexia's network pathologists when additional expertise, capacity, or locum support is needed.
- Use a cloud-based reporting module that includes collaborative features, audit trails, and (in later phases) AI safeguards for case reporting, including AI-driven quality-control (QC) for uploaded slides and automated functions for report coding and data consistency.

This shift represents a strategic transformation: moving from a centralized, Diagnexia-driven service model to a flexible, hybrid ecosystem where customers can operate independently while still leveraging Diagnexia's pathologist network, technology, and regulatory infrastructure.

Because the project introduces new workflows, technologies, and responsibilities across clinical, regulatory, information security, and operational domains, a detailed Quality Risk Assessment is required. This assessment ensures that:

- Regulatory compliance (CLIA, CAP, HIPAA, GDPR, GDPR UK, PIPEDA, CQC, ISO 15189, ISO27001) is not compromised by interstate or international case routing.
- PHI security and access controls are robust, particularly under a BYOD (bring-your-own-device) model for pathologists.
- Interoperability issues between different scanner file formats (TIFF, SVS, etc.) and the Diagnexia platform are managed via DICOM standards.
- AI-driven QC and reporting safeguards are validated before clinical adoption.
- Adequate training, documentation, and SOP updates are in place for internal and external users.

The risk assessment will therefore not only evaluate potential hazards and failure points but also ensure that mitigation strategies are documented, corrective actions are tracked, and residual risks are acceptable in line with Diagnexia's Quality Management System (QMS).

1.1. PURPOSE

The purpose of this Quality Risk Assessment is to:

- 1.1.1. Define the scope and objectives of the My Diagnexia Group Reporting Hub in the context of Diagnexia's regulatory, quality, and commercial framework.
- 1.1.2. Identify risks associated with the introduction of decentralized case reporting, client-side slide uploads, cloud-based reporting tools, and external device use by pathologists.
- 1.1.3. Assess the potential impact of risks on:
 - Patient safety and diagnostic quality
 - Compliance with regulatory requirements (CLIA, CAP, HIPAA, GDPR, GDPR UK, PIPEDA, CQC, ISO 15189:2012)
 - Information security (CIA risks in reference to ISO 27001:2022) and PHI protection
 - Data integrity and long-term storage/retention
 - Operational efficiency and customer satisfaction
 - Commercial objectives of Diagnexia (market adoption, scalability, global expansion)
- 1.1.4. Evaluate the likelihood and severity of identified risks using Diagnexia's established Quality Risk Management (QRM) framework.
- 1.1.5. Propose corrective and preventive actions (CAPAs) to mitigate identified risks, including SOP updates, training programs, technical validation, and regulatory/legal reviews.
- 1.1.6. Ensure alignment between technical implementation (ECO changes, scanner integrations, AI modules), business strategy (customer adoption, commercial growth), and compliance obligations (regulatory approvals, data privacy requirements).
- 1.1.7. Provide a documented reference that can be used by:
 - Regulatory Affairs for compliance audits
 - QA for CAPA tracking and QMS alignment
 - IS and Data Protection and Privacy teams for DPIA and Information security reviews
 - Clinical Operations for training and deployment planning
 - Commercial teams for customer engagement and onboarding

In summary, the purpose of this QRA is to ensure that the *My Diagnexia Group Reporting Hub* is implemented in a controlled, compliant, and risk-mitigated manner, safeguarding patients, customers, and Diagnexia's regulatory standing while enabling the commercial and technological objectives of the platform.

1.2. SCOPE

This Quality Risk Assessment applies to Diagnexia platform users (clients, internal Diagnexia pathologists, and external consultants) operating under the MyDiagnexia Group Reporting Hub. It covers global implementation across Diagnexia's U.S., Canadian, and U.K. laboratories, ensuring alignment with regional regulatory frameworks (CLIA/CAP – U.S., ISO 15189/CQC – U.K., and PIPEDA/HIPAA – Canada). Implementation is planned for October 2025." Remove all references to "Phase 1 / Phase 2.

2. RESPONSIBILITIES

Quality Assurance	Ensure compliance, validate CAPA effectiveness, risk tracking.
Regulatory Affairs Specialist/Legal	Review compliance with CLIA, CAP, HIPAA, GDPR, PIPEDA. To ensure customer contracts reflect the service being offered and comply with relevant laws and regulations.
Information Security & Data Protection	Conduct DPIA, SSO integration review, device security.
Product/Engineering	Implement QC pipeline, case routing, viewer enhancements.
Clinical Ops	Train users, validate workflows, ensure operational readiness.

3. BACKGROUND

The **My Diagnexia** project represents a significant transformation in Diagnexia's global operational and clinical workflows. Historically, Diagnexia has operated under a centralized model in which client slides were physically shipped to the Naperville (U.S.), Toronto (Canada) or Exeter (U.K.) laboratories for scanning, QC, and reporting by Diagnexia's internal or network pathologists. While this centralized model ensured strong regulatory oversight, it introduced logistical delays, higher shipping risks, and limited scalability for clients seeking more flexible and regionally distributed pathology services.

The new Diagnexia Web Viewer introduces global client-side digital uploads, decentralized case assignment, and web-based reporting capabilities. These innovations allow pathology groups across all regions to self-manage their caseloads while retaining the option to route cases to Diagnexia's international network of pathologists. This model enables a synchronized, global deployment and supports Diagnexia's mission to deliver collaborative, compliant, and scalable digital pathology solutions worldwide.

While commercially valuable and aligned with market demand, this transition introduces new regulatory, quality, information security, data protection and operational risks that must be assessed and mitigated prior to the global launch in October 2025.

The risk assessment is required because:

- **Regulatory Compliance:** New workflows must comply with CAP, CLIA (LDT), HIPAA, GDPR, GDPR UK, PIPEDA, ISO 15189, and other international regulatory frameworks governing patient data, diagnostic accuracy, and case assignment across cross-border environments. Case routing and customizable reporting identifiers raise legal and malpractice considerations that require review under regional and international laws & standards.

- **Data Privacy & Security:** Global pathologists and clients will access PHI from institution-owned or approved personal devices, introducing DPIA, SSO, encryption, and access-control requirements. OCR/case ID mismatches and PHI leakage remain key risks requiring ongoing monitoring.
- **Technical Interoperability:** Multiple scanner manufacturers (Leica, Roche, Hamamatsu, Philips, and others) generate diverse image formats (TIFF, SVS, NDPI, etc.). Diagnexia must validate compatibility through DICOM standards and ensure robust QC and metadata workflows across all supported regions.
- **Operational Readiness:** Decentralized uploads and reporting require globally harmonized SOPs for QC, training, case routing, and client support. Internal teams and external users must complete updated competency training to ensure safe, compliant operation across regions.
- **Business Continuity/Retention:** Cloud-based image storage and retention (e.g., WASABI or equivalent) must comply with applicable CAP/CLIA, ISO 15189, ISO 27001:2022 and local jurisdictional requirements for record retention (typically 10–20 years). Disaster recovery and continuity processes must be validated for decentralized, multi-region workflows.

3.1. Summary of Procedures / SOPs

The below table lists all the Procedures for the Deciphex (within scope of this report).

No.	Document ID	Document Name / Title	Version	Comments
1	DMS-8544	Diagnexia Procedure for GLP Quality Assurance Programme	H-1	Core QA oversight for GLP compliance
2	DMS-8080	Procedure for Disaster Recovery	C-1	Ensures BC/DR coverage for cloud-based workflows.
3	DMS-72576	Master Security	A-1	Requires update for cloud viewer, BYOD device validation, BC/DR.
4	DMS-8060	Privacy Policy / DPIA	B-1	Covers HIPAA, GDPR, PIPEDA compliance, SSO, cookies/consent.
5	DMS-20398	Software Rollout / Validation	C-1	Defines rollout testing, CAP validation, and ECO controls.
6	DMS-94327	Pathologist Onboarding/Training	A-1	Must be updated for Group Reporting workflows and device validation.
7	DMS-69916	Scanner Integration & Interoperability	A-1	Defines scanner connectivity, DICOM conversion, LIS/LIMS interoperability.
8	DGX-MAN-47	User Guide – Client Portal	1.0	Requires update for self-assign workflows and web

No.	Document ID	Document Name / Title	Version	Comments
				 DGX-MAN-47 Diagnexia Customer Portal USA- ... reporting.
9	DMS-24379	Diagnexia Procedure for Case Assignment	E-1	Governs case manifest/QC logic; to be updated for client-side assignment.
10	DMS-8105	Pathology Reports	H-1	Defines report generation, metadata, and CAP/CLIA reporting compliance.
11	DMS-8333	Diagnexia Policy for Secure Software Development LifeCycle	H-1	Details the Software Lifecycle approach
12	DMS-106470	Privacy policy US and Canada	A-1	New document (similar to 8060)
13	TBD	Diagnexia Validation Plan - all regional labs (build a Template for test cases)	A-1	New document (Appendix A/B/C)
14	DMS-8330	Policy for Mobile Device and Remote Working	C 1	Policy to be updated as BYOD devices will include laptops in reference to the service.

4. SUMMARY OF GAPS/DEVIATIONS IDENTIFIED

No	Description	Impact Assessment	Risk Assessment	Actions to resolve
1	Regulatory gaps in interstate/international case routing	May breach CLIA/CAP standards	High (8–12)	RA review, define CLIA ID ownership model, update reporting SOPs
2	Legal issues with interstate/international case routing	Malpractice exposure	High (8–12)	Legal review
3	PHI access across decentralized pathologist devices (BYOD)	Potential HIPAA/PIPEDA non-compliance; uncontrolled PHI access	Extreme (15–20)	1)Enforce SSO/ MFA for system access based on customer preference . 2)Recommended minimum security specs : -Reduce risk from Data At Rest Risk by leveraging Full Disk Encryption (e.g. Bitlocker) -Reduce risk of Data At Rest risk by setting timed Screen Locks and mandating Privacy Screens for users who will be using devices in public locations -Platform Data In Transit risk is mitigated by the use of Transport Layer Security, customers can further reduce risk by mandating VPNs are used when accessing patient data outside of customer controlled networks

No	Description	Impact Assessment	Risk Assessment	Actions to resolve
				-Reduce the risk of being actively comprised by installing an Anti-Virus solution and keeping it up to date with the latest definitions and updates -Mandate a specific web browser to be used and ensure it is kept up to date. 3) DPIA update
4	OCR/case ID mismatches	Misattributed cases; delays in reporting	Moderate (5–6)	Implement QC fallback, metadata correction workflow
5	Scanner interoperability issues (TIFF, SVS vs DICOM)	Blocked/failed cases; loss of diagnostic continuity	High (8–12)	Validate DICOM conversion tools, customer UAT
6	AI/Web reporting usability not validated	Risk of incorrect or incomplete pathology reports	High (8–12)	Validate AI QC safeguards, CPT auto-coding, minimum spec screens
7	Training/onboarding gaps (internal & external)	Misuse of system; regulatory non-conformance	Moderate (5–6)	Update user guides, require attestation training records
8	Data storage/retention gaps	Non-compliance with CAP/CLIA retention (10–20 years)	High (8–12)	Validate cloud/WASABI storage, confirm DR procedures
9	System outage/business continuity gaps	Service disruption, reporting delays	High (8–12)	Align with DMS-8080, test DR processes
10	Billing/reporting logic not fully defined	Misbilling; contractual disputes	Moderate (5–6)	Define configurable billing metadata; validate Coronis automation
11	Clinical equivalency between existing	Consider 42 CFR 493.1253	High (8-12)	Define a validation master plan for the

No	Description	Impact Assessment	Risk Assessment	Actions to resolve
	Diagnexia configuration and new configuration "MyDiagnexia"	equivalent testing		entire workflow with factory configuration settings. Appendix A
12	Process & testing gap: Software deployment to Clinical release by US Medical Lab director	CAP: GEN.43022 LIS testing CAP: GEN.52920 WSI System validation / verification	High (8-12)	<i>DMS-20398.C1 needs updating.</i> <i>DMS-8333.H1 needs review.</i> <i>DMS-29682 Pathologist testing</i>
13	IQA tools used in Diagnexia have a quality plan approach.	DMS-84173 - Intended Purpose DMS-94005 - IFU	Extreme (15-20)	The IQA tools were designed to be retrospective data learning models that do not make clinical decisions. They will require an impact review for intended use if they are used in pre-DX flow .

5. CORRECTIVE ACTIONS

The section below provides the detail of the open actions items due to the above risks:

Item ID	Action	Next Steps	Due Date	Responsible Person
CA-01	Regulatory review of interstate/international routing	Legal/RA to draft guidance on CLIA ID ownership	TBD	Regulatory Affairs
CA-02	Device security validation	IS to define minimum specs, update DPIA, enforce SSO	TBD	Information Security
CA-03	QC process for OCR/case ID	Engineering to implement fallback QC & metadata correction workflow	TBD	Product/Engineering
CA-04	DICOM interoperability	Validate conversion pipeline, run pilot UAT with customer scanners	TBD	Engineering & QA
CA-05	AI/Web reporting safeguards	Validate AI-driven QC process for slide uploads; validate	TBD	QA & Product

Item ID	Action	Next Steps	Due Date	Responsible Person
		automated CPT coding and screen resolution requirements as distinct (non-AI) workflows.		
CA-06	Training attestation	Update user guides, ILT training with recorded evidence	TBD	Clinical Ops
CA-07	Storage/retention compliance	Validate WASABI retention; align with CAP/CLIA retention policies	TBD	QA & IS
CA-08	BC/DR readiness	Update and test recovery procedures for cloud workflows	TBD	Information Security & CTO
CA-09	Billing workflow validation	Define billing metadata; confirm Coronis integration	TBD	Product/Finance, Clinical Ops
CA10	Medical Necessity - eCFR	Ordering physicians may only order medical necessary tests - case assignment flow between providers	TBD	Regulatory Affairs
CA11	Validation test plan - end to end	RA will outline the testing requirements based on regulatory conditions. <i>(will require consultation with clinical and pathology to ensure medicine, legal requirements)</i>	TBD	Regulatory Affairs will deliver to QA & Marketing / OPS
CA12	Procedure updates	QA to advise the process for implementation <i>(potentially ECO for each site or leverage existing processes)</i> • DGX-MAN-06.05 - draft • DMS-8105.H1 → I1 -  • DMS-	TBD	Assistance from QA
CA13	IQA tools: Colorectal & Dermatopathology	Quality plan to address how the tools meet retrospective reviews. If IFU changes to pre-diagnosis, update requirements.	TBD	Quality Assurance

6. DEPENDENCIES

Multiple Engineering Change Orders may be necessary to ensure a complete solution to market is adhering to patient safety, regulatory compliance, and ensuring least disruption to operational service provided to clients. Because multiple changes are being introduced in overlap, risk may be introduced with change releases. Refer to [APPENDIX A](#)

Below is a summarized table of ECOs to be reviewed:

ECO number	Description
ECO-102374	QC Application (ADLC) - stand alone AI-powered QC application that detects artifacts, routes problematic slides for manual review
ECO-76940	WASABI storage capacity (cheaper US solution)
ECO-91194	AI - Clinical AI-IQA Dermatopathology Screening Tool - refer to DMS-84173
ECO-91190	AI - Clinical AI-IQA Colorectal Screening Tool - refer to DMS-94005
ECO-77625	Case Assignment Tool - (software) filters eligible pathologists by criteria, prioritizes cases, and auto assigns the case to pathologist

7. CONCLUSION

The risks associated with the My Diagnexia Group Reporting Hub are significant but manageable with proper mitigation.
Key risk domains: regulatory compliance, PHI security, device validation, scanner interoperability, and AI/web reporting validation.

Residual risk is acceptable contingent upon:

- Completion of DPIA & IS review
- Validation of DICOM compatibility & AI safeguards
- Formal training/attestation for all users

The QRA will be reviewed quarterly post-implementation and updated as corrective actions are closed.

8. DEFINITIONS & GLOSSARY

Abbreviation	Definition
AI QC	Artificial intelligence-based quality control for uploaded slides
AI Safeguards	Artificial-intelligence–based quality-control features within the MyDiagnexia platform that assess slide adequacy (focus, completeness, and labeling) before reporting. <i>Note:</i> Other platform safeguards such as CPT code population and metadata correction are automated processes but are not AI-driven.
BC/DR	Business Continuity and Disaster Recovery
BYOD	Bring Your Own Device (personal or institution-owned devices used by pathologists)
CAP	College of American Pathologists – accreditation standards
CLIA	Clinical Laboratory Improvement Amendments – U.S. federal regulatory standards
DICOM	Digital Imaging and Communications in Medicine – standard for image interoperability
DPIA	Data Protection Impact Assessment
HIPAA	Health Insurance Portability and Accountability Act (U.S. privacy/security regulation)
IMS	Integrated Management System (Deciphex/Diagnexia)
OCR	Optical Character Recognition used for slide/case ID matching
PHI	Protected Health Information
QMS	Quality Management System

Abbreviation	Definition
QRA	Quality Risk Assessment
SOP	Standard Operating Procedure
SSO	Single Sign-On (secure access control)
UAT	User Acceptance Testing
LDT	Laboratory Developed Test
ISO 27001:2022	Information security, cybersecurity and privacy protection — Information security management systems — Requirements
ISO 15189:2022	Medical laboratories — Requirements for quality and competence

9. DOCUMENT REFERENCES

Include any document references. Remove the below references if not relevant.

The below procedures and registers contain processes that may benefit from risk assessment and this template.

[Deciphex Procedure for Incident Management](#)

[Deciphex Management Review](#)

[Deciphex Procedure for Data Protection Impact Assessment](#)

[Diagnexia Master Security Document](#)

[Deciphex Procedure for Quality Management](#)

[Deciphex Quality Risk Management Process](#)

[Deciphex Supplier Management Register](#)

[Deciphex Procedure for Risk Management](#)

[Deciphex Risk Register](#)

[Diagnexia UK Risk Register](#)

DMS-8321 Deciphex Policy for Information Security

DMS-8325 Policy for Business Continuity

DMS-8080 Deciphex Procedure for Disaster Recovery

DMS-8054 Policy for Acceptable Usage

DMS-8324 Deciphex Policy for Bring Your Own Device

10. PUBLISHING

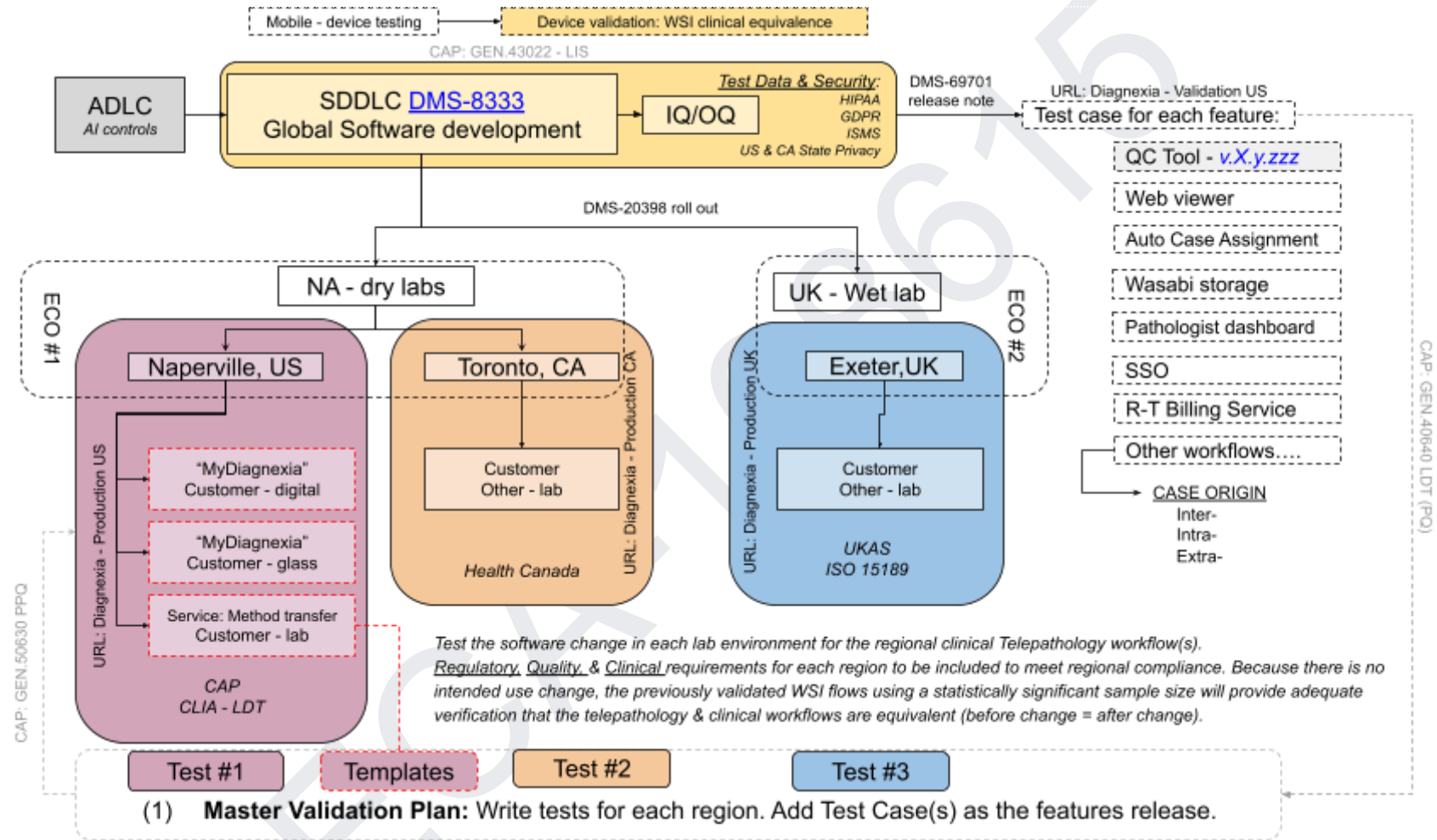
The signed document is stored in the IMS Document Control Library.

11. REVIEW

This document is required to be reviewed on a periodic basis as defined in the document control register to ensure that the procedure is relevant and does not require any change. An ad-hoc review may be required in response to any legislative, regulatory, contractual, organizational change or significant security incident or breach.

The Document Control Register is used to control and record the review completion and next review dates.

12. APPENDIX A



APPENDIX B: IQ - OQ - PQ - PPQ Master validation testing defined across feature release scope

Validation		Process control	Feature,workflow, (test case) to be evaluated: ✓ test ✗ not necessary to test	Test Y or N
Acronym	Validation definition	DMS-xxxxx		
IQ	Installation Qualification: <i>Verifies equipment / software is installed correctly per design and manufacturer specifications.</i>	DGX-MAN-06 DMS-68241 DMS-8109	- Workstation device(s) - Remote device configurations - SSO & MFA	✓ ✓ ✓
		DMS-8333 - SDLC	Cloud & Premise software installations	✓
		Vendor	Install records from scanner vendor	✗
OQ	Operational Qualification: <i>Confirms equipment / software operates as intended within set parameters.</i>	DCX-OPQR-30 DCX-OPQ-07	- US, CA Scanner device: WSI - UK Scanner: WSI	✗ ✗
		DMS-8333 - SDLC	FRS testing for each feature	✓
		DMS-72576 DCX-IQR-198 DCX-IQ-08	- Pen testing, downtime recovery, security - SSO & MFA - Wasabi storage	? ✓ ✓
PQ	Performance Qualification: <i>Ensures equipment / software performs reproducibly under intended use conditions (e.g. end users, lab location, clinical application).</i>	DCX-OPQR-30 DCX-OPQ-07 <i>Test case - new</i> <i>Test case - new</i> <i>Test case - new</i> <i>Test case - new</i>	- US, CA Scanner device: WSI - UK Scanner: WSI - Integration testing - Billing - QC cloud tool - SSO & MFA - Auto Case Assignment	✗ ✗ ✓ ✓ ✓ ✓
PPQ	Process Performance Qualification: <i>Demonstrates evidence that a process consistently performs within established parameters to deliver expected results.</i>	DMS-29682 - US DMS-24380 - CA DMS-24009 - UK	- Pathologist Web Viewer - Clinical - Pathologist Dashboard	✓ ✓
Customer / Services	Method Transfer: <i>The receiving lab revalidates affected parameters under its specific conditions (e.g. environment or patient samples).</i>	DMS-81702 - Plan DGX-FRM-80 - UAT DCX-FRM-47 - PPQ	Service delivery to the customer - <i>method transfer into their laboratory environment for their patient population.</i>	N/A

APPENDIX C:

C1. US & CA Regulatory References - *Equivalence testing requirements*

Regulatory reference	Requirement	Requirement Description	Evidence Record
CLIA: 42 CFR 493.1253	Standard: Establishment and verification of performance specifications.	(1) Verification of performance specifications. (a) Accuracy. (b) Precision. (c) Reportable range of test results for the test system. (2) Establishment of performance specifications. (a) Accuracy. (b) Precision. (c) Analytical sensitivity. (d) Analytical specificity to include interfering substances. (e) Reportable range of test results for the test system. (f) Reference intervals (normal values). (g) Any other performance characteristic required for test performance. (3) Determination of calibration and control procedures. (4) Documentation.	▶▶ Refer to CAP: COM.40640 - same requirement - this is the LDT.
CAP: COM.40475	Method Validation and Verification Approval - nonwaived tests	Prior to clinical use of each nonwaived test, the laboratory director, or designee meeting CAP director qualifications, has signed the laboratory's written assessment of the validation or verification study (accuracy, precision, etc.) to confirm the acceptance of the study data and written assessment, and to approve each nonwaived test for clinical use. NOTE: This checklist requirement is applicable only to nonwaived tests implemented after June 15, 2009; however, all nonwaived tests must have records of completed analytical validation or verification, regardless of their implementation date. The approval must include: 1) review of the written assessment of the validation or verification study, including the acceptability of the data and investigation of any discordant results; 2) signed approval statement, such as, <i>"I have reviewed the verification (or validation) data for the performance specifications listed below for the (insert instrument/test name), and the performance of the method is considered acceptable for patient testing."</i> If a validation or verification study (<i>accuracy, precision, reportable range, etc.</i>) was not performed or is missing required components, the appropriate, related checklist requirements must also be cited (eg, COM.40300, COM.40350). If multiple identical instruments or devices are in use, there must be records (data and written assessment) showing that the method performance specifications have been separately validated/verified for each test and instrument or device	✓ Records of approval of validation and verification studies <u>and</u> approval for clinical use ✓ The Medical Director or CMO would sign report with attestation statement. ✚ Consider MEMO cover sheet with reference to the test records. ✓ Each instrument needs testing. ✚ Repeat in Canada.

Regulatory reference	Requirement	Requirement Description	Evidence Record
CAP: COM.40640	Clinical Performance Characteristics Validation - Laboratory-developed Tests	The laboratory validates clinical performance characteristics for laboratory-developed tests. NOTE: Clinical performance characteristics include statements about a test's sensitivity and specificity, and may include determining predictive values for relevant disease(s) or condition(s), as applicable. These characteristics must be established by the laboratory unless the clinical validity of the test is documented in peer-reviewed literature or textbooks. The clinical validation study must include at <u>least 20 samples</u> and must include both <u>positive</u> and <u>negative samples</u>. <i>If the laboratory uses fewer samples, the laboratory director must record the criteria used to determine the appropriateness of the sample size.</i> ✚ Consider MEMO for each test case justifying when validation is not necessary.	✓ Records of clinical studies performed by the laboratory <u>OR</u> peer-reviewed literature that reasonably substantiates all claims made by the laboratory about a test ✓ <i>Reference previous validation record IDs.</i> ✚ <i>Repeat validation samples to demonstrate equivalence (before change = after change)</i>
CAP: GEN.50630	Telepathology System Validation	The laboratory validates telepathology systems used for clinical diagnostic purposes by performing its own validation studies, including approval for use by the laboratory director (or designee who meets CAP director qualifications) before the technology is used for the intended diagnostic purpose(s). NOTE: The specific components of the validation study are left to the discretion of the laboratory. As general guiding principles, the validation process should: ✓ Closely emulate the real-world clinical environment and involve specimen preparation types and clinical settings relevant to the intended use(s). ✓ Be carried out by a pathologist(s) adequately trained to use the system. <i>Refer to GEN.52920 for requirements on validation of whole slide imaging.</i>	✓ Records of completed validation study with review and approval. ✚ Dr. Mattoch willing to test this flow? <i>This would be a small test case as the last step.</i>
CAP: GEN.51728	Telepathology Training	The laboratory trains all users of the telepathology system as appropriate to their role. ✓ Oranos training R&U to User Guide changes [DGX-MAN-47] - Admin role ✓ Bamboo training R&U to [DMS-20398] notification - Pathologist role	✓ Records for telepathology training in personnel files
CAP: GEN.52920	Whole Slide Imaging System Validation/Verification	The laboratory validates or verifies <u>whole slide imaging systems</u> used for clinical diagnostic purposes by performing its own studies, including approval for use by the laboratory director (or designee who meets CAP director qualifications) before the technology is used for the intended diagnostic purpose(s). ✓ This might only be needed for glass flow (not 100% digital flows)	✓ Records of completed validation or verification study with review and approval ✓ DCX-OPQR-30 - NA ✓ DCX-OPQ-07 UK

Regulatory reference	Requirement	Requirement Description	Evidence Record
CAP: GEN.52900	Whole Slide Imaging User Training	There are records showing that all users of the whole slide imaging system have been trained.	☒ Records for whole slide image training in personnel files ✓ Manufacturer training records to the scanners. (Hamamatsu, Glissando, etc.)
CAP: GEN.43022	LIS Testing <i>(Portal Admin)</i>	Programs are adequately tested for proper functioning when first installed and after any modifications, and the laboratory director or designee has approved the use of all new programs and modifications NOTE: Computer programs must be checked for proper performance when first installed and after any changes or modifications, including assessment after implementation in the live (production) system. Any <u>changes or modifications</u> to the system must be recorded, and the laboratory director or designee must approve all changes, additions and deletions in programs, the test library, and major computer functions before they are released. This applies both to locally installed and remotely hosted software. Testing should include reference intervals, critical values and/or verification limits, and operational rules/algorithms. Rules producing reported patient results or result interpretation are addressed in <u>*GEN.43450</u>. Records must be retained for at least two years beyond the service life of the system. <i>*Not applicable to North America Diagnexia Laboratories</i>	☒ Records of testing and approval. + Justify with IQ / OQ software team record?

C2. UK Regulatory References - *Equivalence testing requirements*

Regulatory reference	Requirement	Description	Evidence Record
ISO 15189 - applies to Exeter Laboratory, UK			
	Sec (7.6.2)	The laboratory shall ensure that the authorities and responsibilities for the management of the information systems are specified, including the maintenance and <u>modification to the information systems</u> that can affect patient care. The laboratory is ultimately responsible for the laboratory information systems.	✓ Record for verification / validation.
	Sec (7.6.3)	<u>Information systems management</u> The system(s) used for the collection, processing, recording, reporting, storage or retrieval of examination data and information shall be: a) validated by the supplier and verified for functionality by the laboratory before introduction. Any changes to the system, including laboratory software configuration or modifications to commercial off-the-shelf software, shall be authorized, documented and validated before implementation; NOTE 1 Validation and verification include, where applicable, the proper functioning of interfaces between the laboratory information system and other systems such as laboratory equipment, hospital patient administration systems and systems in primary care. NOTE 2 Commercial off-the-shelf software used within its designed application range can be considered sufficiently validated (e.g. word processing and spreadsheet software, and quality management software programs).	✚ Performance Qualification
		b) documented, and the documentation readily available to authorized users , including that for day to day functioning of the system	✓ User Guide(s): DGX-MAN-47 DGX-MAN-13
		c) implemented taking cybersecurity into account, to protect the system from unauthorized access and safeguard data against tampering or loss;	✚ Tested by IO / OQ (FRS) software team
		d) operated in an environment that complies with supplier specifications or, in the case of non computerized systems, provides conditions which safeguard the accuracy of manual recording and transcription;	✚ Downtime procedure
		e) maintained in a manner that ensures the integrity of the data and information and includes the recording of system failures and the appropriate immediate and corrective actions.	✚ Business continuity DMS-40393 Diagnexia Policy for

Regulatory reference	Requirement	Description	Evidence Record
		Calculations and data transfers shall be checked in an appropriate and systematic manner.	<i>NA Business Continuity</i> DMS-8325 (<i>Global policy</i>) --> DCX-IQR-198 DCX-IQ-08 & DCX-SPC-10 --> DMS-72576.A1)
ISO 27001:2022	A.5.1 to A.5.37	Organisational Controls: • Ensure compliance to DMS-8321 Deciphex Policy for Information Security compliance • Roles and Responsibilities are to be aligned to DCX-REG-55 - IMS Roles & Responsibilities Register • Ensure Segregation of duties to management of product and service offerings to confirm no single person can compromise a critical process /work flow/system. • Define the management of information security requirements in agreements with suppliers and third parties used for the service, if there is any supplier/third party involvement. • Implement and validate adequate controls emphasizing the need to assess and manage risks associated with using cloud services. • Threat Intelligence monitoring to be implemented to validate the to collect and analyze information on current threats to develop appropriate defenses. • Align Information classification reference to DMS-8331 Deciphex Policy for Information Classification based on its value and sensitivity to ensure it is protected appropriately. • Ensure legal, statutory, regulatory, and contractual requirements related to personally identifiable information (PII) privacy and protection is adhered to reference to the jurisdiction the service is provided. • Ensure ICT Readiness for the service provided by planning BC /DR Testing prior to Go Live Phase to document evidence as to new product offering..	• DMS-8321 • DCX-REG-55 • DMS-8331 • DMS-8325 • DMS-8080
	A.6.1 - A.6.8	People Controls • Validate people controls are aligned with DMS-8076 Deciphex Procedure for Human Resources. • People Controls to include adequate training for staff / pathologist/ contractors / internal stakeholder who will oversee and support the service offering reference to DMS-8082 Procedure for Training.	• DMS-8076 • DMS-8077 • DMS 8082

Regulatory reference	Requirement	Description	Evidence Record
		Ensure staff / pathologist/ contractors / internal stakeholder are aware of DMS-8077 Deciphex Procedure for Incident Management to report incidents following the procedure requirement	
	A.7.1 - A.7.14	Physical Controls - Physical Security Controls are implemented in reference to DMS-8068 Deciphex Policy for Physical Security - Validation of Physical Security Controls for US site to be confirmed planning Internal ISO 27001 Audit for the site in Nov 2025 - Extn of Scope to include US site to the current ISO 27001:2022 to be planned and completed in Dec 2025 following the confirmation from BSI , which would additionally validate site specific Physical Controls - My Diagnexia is hosted in SOC 2 Compliant AWS which further validates controls implemented for the data centres which are in use.	- DMS 8068 - Master Security Document (US)
	A.8.1 - A.8.34	Technological Controls - MFA and SSO to be enabled for the system and validated to minimise information security risks - Device Minimum Security Specification to be defined and validated before enabling access for users as the service offering allows BYOD . - Data Masking (A.8.11), Data Leakage Prevention (A.8.12), and Information Deletion (A.8.10) to be implemented and confirmed for the system reference to DMS-8323 Deciphex Policy for Acceptable Encryption to prevent sensitive data exposure and ensure data is securely removed when no longer needed. - User Endpoint Devices (A.8.1), Privileged Access Rights (A.8.2), and Secure Authentication (A.8.5) to be mandated securing user devices, limiting high-level system access, and implementing multi-factor authentication (MFA) reference to DMS-8055 Deciphex Policy for Access Management & DMS-8081 Deciphex Procedure for Access Management - Protection Against Malware (A.8.7), Configuration Management (A.8.9), and Vulnerability Management (A.8.8) ensure systems are securely configured, patched, and protected from malicious software reference to DMS-8327 Deciphex Policy for Vulnerability Management & DMS-8016 Deciphex Procedure for Patch Management. - Network Security (A.8.20), Web Filtering (A.8.23), and Segregation of Networks (A.8.22) cover securing network boundaries, controlling access to internet resources, and separating critical systems to be confirmed to mitigate risks. - Adherence to be DMS-8329 Deciphex Policy for Monitoring of Systems Containing PHI to be confirmed as the system holds PHI and to minimise risks.	- DMS-8323 - DMS-8055 - DMS-8081 - DMS-8327 - DMS-8016 - DMS-8329 - DMS-8073 - DMS-8077 - DMS-8318

Regulatory reference	Requirement	Description	Evidence Record
		- Secure Coding (A.8.28), Security Testing in Development and Acceptance (A.8.29), and Change Management (A.8.32) to be confirmed integrate security requirements into the entire system development lifecycle. Any changes planned should follow DMS-8318 Deciphex Policy for Change Management to minimise operational disruptions, minimise risks, ensure stakeholder awareness and engagement. - Internal ISO 27001 Audits to be planned to ensure the Technical Controls reference to DMS-8073 Deciphex Procedure for Audit Management to ensure policy and procedure compliance. - All incidents are to be reported in reference to DMS-8077 Deciphex Procedure for Incident Management.	